

LEDGR Information Security Policy

- Document owner: Branden Nevius (Founder / Engineering)
- Security contact: brandennevius@gmail.com
- Effective date: 2026-02-15
- Last reviewed: 2026-02-15
- Review cadence: At least annually, and after material architecture changes
- Version: 1.0

1) Purpose

This policy defines how LEDGR identifies, mitigates, and monitors information security risks for systems that process customer financial and personal data.

2) Scope

This policy applies to:

- LEDGR web application and related API services
- Mobile clients that access LEDGR APIs
- Data stores and infrastructure that process Plaid-derived or user-provided financial data
- Personnel and contractors with access to production systems or sensitive data

3) Security Governance

LEDGR currently operates as a founder-led engineering organization. The owner listed above is accountable for:

- Security policy maintenance and annual review
- Risk assessment and remediation tracking
- Incident response coordination
- Vendor security oversight

4) Risk Management Program

LEDGR runs an ongoing risk management process:

- Maintain a risk register for material risks to confidentiality, integrity, and availability
- Reassess top risks at least quarterly
- Perform change risk review before launching new financial-data features or new third-party vendors
- Track mitigation actions with owner and target date

Risk levels:

- High: Remediate immediately or block release
- Medium: Remediate within 30 days
- Low: Remediate in normal engineering cycles

5) Identity and Access Management

Required controls:

- Unique user accounts for all production systems
- Role-based access control (RBAC) is used to assign access by job function and system role

- Least-privilege access based on business need
- Access removal within 24 hours of role change or termination
- No shared credentials for privileged systems
- MFA required for administrative access to critical systems when the provider supports MFA
- Quarterly access review of production and data systems

6) Data Protection

Data handling requirements:

- Only collect data needed for product features and support operations
- Do not commit secrets, API keys, or tokens to source control
- Store secrets in environment variables or managed secret stores
- Restrict production data access to authorized personnel only
- Use test/sandbox data where practical for development and demos

Encryption requirements:

- Encrypt data in transit using TLS 1.2+ for client-to-server and server-to-vendor communication
- Store data at rest in managed infrastructure with at-rest encryption controls enabled by the provider

7) Application Security and SDLC

LEDGR development security requirements:

- Validate authentication and authorization on all protected API routes
- Validate input on API endpoints and reject malformed requests
- Keep framework and dependency versions current and patch known vulnerabilities
- Review security impact for changes affecting Plaid, auth, payments, or data models
- Verify webhook authenticity for security-sensitive integrations

8) Logging, Monitoring, and Alerting

LEDGR will maintain operational visibility for:

- Authentication failures and access anomalies
- Errors on Plaid integration endpoints
- Production incidents affecting data synchronization or user access

Monitoring sources may include hosted platform logs and provider dashboards.

9) Incident Response

If a security incident is suspected:

- Triage severity and scope immediately
- Contain impacted services and rotate credentials when indicated
- Document timeline, affected systems, and remediation
- Notify impacted users/regulators/partners when legally or contractually required
- Complete a post-incident review with corrective actions

10) Vendor and Third-Party Risk

For vendors that process or can access sensitive data (for example: Plaid, Supabase, hosting providers, AI providers):

- Review vendor security documentation before production use
- Limit shared data to minimum required for the feature
- Maintain an inventory of critical vendors and integration purposes

11) Data Retention and Deletion

LEDGR must maintain and enforce a retention/deletion practice that is consistent with product and legal requirements:

- Retain customer data only as long as needed for service delivery and compliance
- Support account-level data deletion workflows
- Periodically review retained data and remove stale data where appropriate

12) Exceptions

Any exception to this policy must include:

- Business justification
- Risk acceptance by the document owner
- Expiration date and remediation plan

13) Policy Operational Status (as of 2026-02-15)

This section is included so external compliance responses remain accurate.

Implemented now:

- Authenticated API routes enforce authorization checks
- Plaid webhook signature verification route is implemented
- Plaid access credentials are stored server-side, not client-side
- Data deletion endpoints exist for account/transaction cleanup

In progress / requires formalization:

- Written evidence of quarterly access reviews
- Written risk register and periodic risk review log
- Formal vulnerability management runbook and patch cadence log
- Formal incident-response playbook with contact tree